

WEB SECURITY

- Web security protects **web applications** from the harmful events performed by the attackers.
- The **main function of securing network is to provide protection against Transmission Control Protocol/Internet Protocol (TCP/IP) attacks.**
- In transport layer, this can be **achieved by Secure Sockets Layer/Transport Layer Security (SSL/TLS).**
- Then, secure web applications can be designed by **analysing the categories of threats** and thereby **incorporating security in the developed application.**
- **Secure Electronic Transaction (SET)** is a key example for a web application with secure features.

Secure Electronic Transaction (SET)

- Global reach of Internet encourages online transactions.
- **Secured encryption technology** is needed **to support secure E-commerce** in the Internet.
- SET is an open encryption and security standard specification that **ensures secure financial transactions performed in the Internet through a debit or credit card received from a bank.**
- SET was developed by **VISA and MasterCard** with the support of GTE, Microsoft, IBM and Netscape.

- The SET uses Netscape's SSL, Microsoft's Secure Transaction Technology (STT), Secure Hyper Text Transfer Protocol (S-HTTP) and some aspects of public key infrastructure.
- The **cardholder's information is secured by the SET** since it travels across an insecure network (Internet).
- The main advantage of SET is that, **it securely conceals the Order Information (OI) and Payment Information (PI)**, so that **bank cannot find order information and the merchant cannot find the details of payment information.**

Actors in SET

The **main actors in SET** are **merchant (recipient), acquirer, customer (cardholder), issuer (bank), payment gateway and CA.**

1. **Merchant (Recipient):** Merchant is a **person or an enterprise** that has **goods to sell to the customers in an electronic environment.** Merchant will have a **tie-up with acquirer through payment gateway.**
2. **Acquirer:** Merchant has **an account with the acquirer for payment and payment card authorization.** **Merchant accepts various types of payment cards with the assurance of acquirer.** The acquirer provides

payment authorization to transfer the payment to the merchant account after delivering the goods to the customer.

3. **Customer (Cardholder):** Cardholder or customer is a person who interacts with the merchant to buy some products. In order **to initiate purchase request, he/she holds a payment card which is provided by an issuer.**

4. **Issuer (Bank):** A financial organization such as bank who provides **payment card to the customer with authentication.**

5. **Payment Gateway:** The Payment Gateway is an **interface between the merchant and Acquirer.** It supports money transfer and settlement.

6. **Certification Authority:** An entity that issues **X.509v3 public key certificates to cardholders, merchants, acquirer, issuer and payment gateways.**

How SET works?

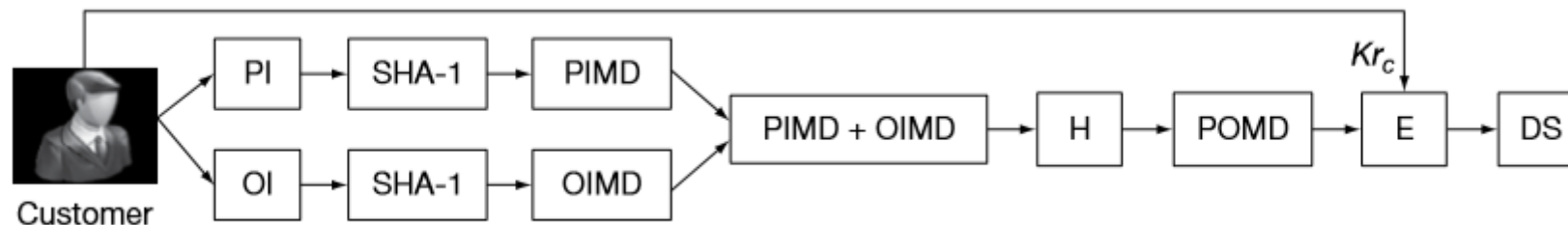
1. Initially, the customer sends **order request to the merchant**.
2. The merchant **verifies** the order request and **confirms the order to the customers**.
3. After getting confirmation from the merchant, the customer **sends payment related information and order related information to the merchant**.
4. The **merchant extracts order related information and forwards the payment related information to the acquirer through payment gateway**.
5. The **acquirer communicates with the issuer and gets confirmation from the issuer** that the customer does not exceed his/her limit.
6. After that the **acquirer gives payment authorization message to the merchant through payment gateway**. Finally merchant delivers the goods to the customer.
7. The **CA takes the responsibility of providing private and public keys to all the components in the form of certificates**.

Functionality of SET

- Initially, **both the customer and the merchant should register their details with the CA.**
- Then, the **SET enables the merchant to authorize the user as a legitimate user** with a valid card **by checking the public key received from the CA.** It uses X.509v3 digital certificate and RSA based signatures to provide authentication in the SET.
- As initialization procedure, **the cardholder and merchant exchange their public keys to each other** as digital certificates provided by the CA.
- In the SET, **information sent from customer to the merchant** are **payment information (PI) and order information (OI).**
- The **SET ensures that the information sent from customer to merchant is not altered during the time of transaction.**
- The cardholder **enters his/her private key to create a Dual Signature (DS) on the order and the payment.**

1. Creation of Dual Signature

- The DS is a **new concept** which is **introduced in the SET** to provide the facility of privacy.
- The DS is used for **concatenating two different messages** that are intended for two different persons in a single message.
- Hence, the customer creates the DS in such a way that the merchant **can view the order information and hence merchant cannot view the payment-related information**.
- Similarly, the **bank can view the payment-related information and hence the bank cannot view the order-related information**.
- In order to do that, the customer initially **computes MDs of payment- and order-related information**. For computing the MD, **Secure Hashing Algorithm-1 (SHA-1)** is used. These MDs are denoted as **PIMD (Payment Information Message Digest) and OIMD (Order Information Message Digest)**.

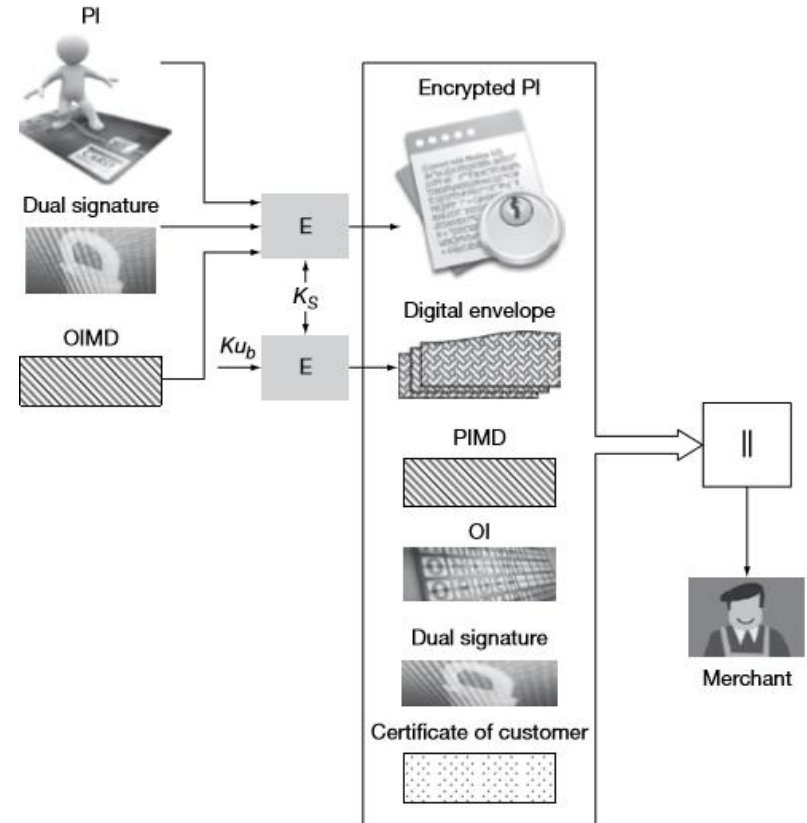


- After creating the PIMD and OIMD values, these **two values are concatenated** and the result is sent into a **hash function**.
- The final result is called **Payment Order Message Digest (POMD)**. This POMD is further encrypted using the **private key of card hold to produce the DS**.

2. Purchase request message created by the customer

- The SET **consists of two phases**, namely **purchase request and purchase response**.
- During the purchase request, the cardholder has to send **order- and payment-related information** to the merchant and to the bank.
- In the purchase response, the merchant responds with the cardholder.
- If the cardholder's transaction is valid, then the merchant delivers the goods to the cardholder.

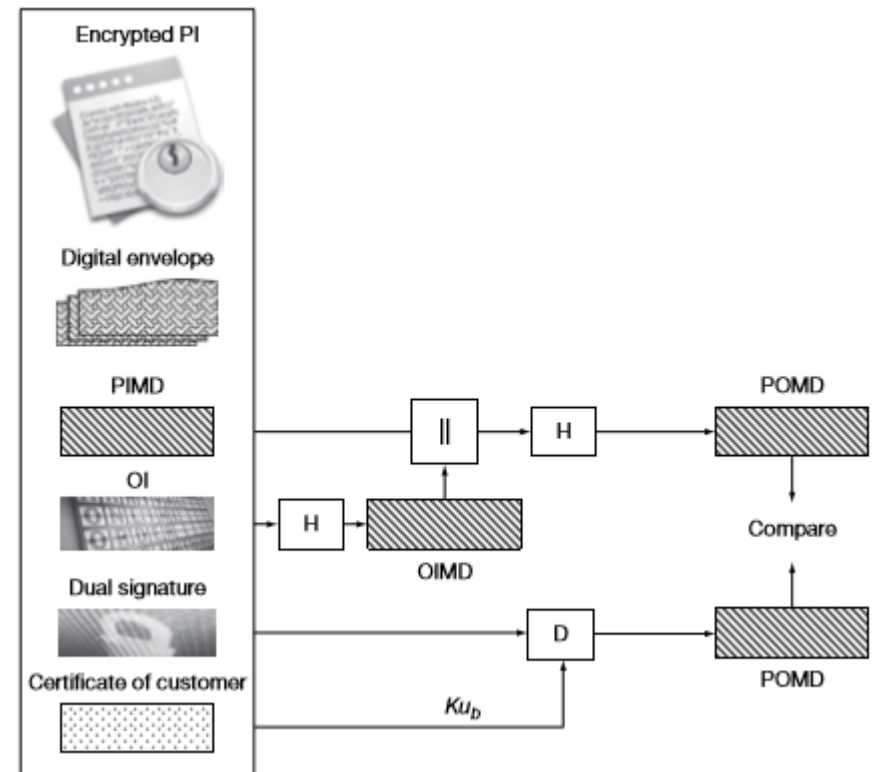
- For creating the purchase request message, the cardholder **initially creates the DS.**
- After creating the DS, it generates a random session **key value K_S** to **encrypt the payment-related information.**
- After generating the session key, it encrypts the session key using the **public key of bank K_{ub}** .
- This can be decrypted by using the **private key of bank K_{rb}** .
- This is called **digital envelope** and is used for finding the randomly generated session key by the bank.
- This digital envelope is created based on encryption performed using the **public key of the bank with the RSA algorithm.**
- After creating the digital envelope, the customer encrypts the PI, DS and OIMD using the session key generated by the customer's browser software.



- This provides additional confidentiality to the PI of the transaction. This result is denoted as encrypted PI.
- Finally, the customer sends encrypted PI, digital envelope, PIMD, OI, DS and certificate of customer (cardholder) to the merchant.

3. Verification of DS and purchase response

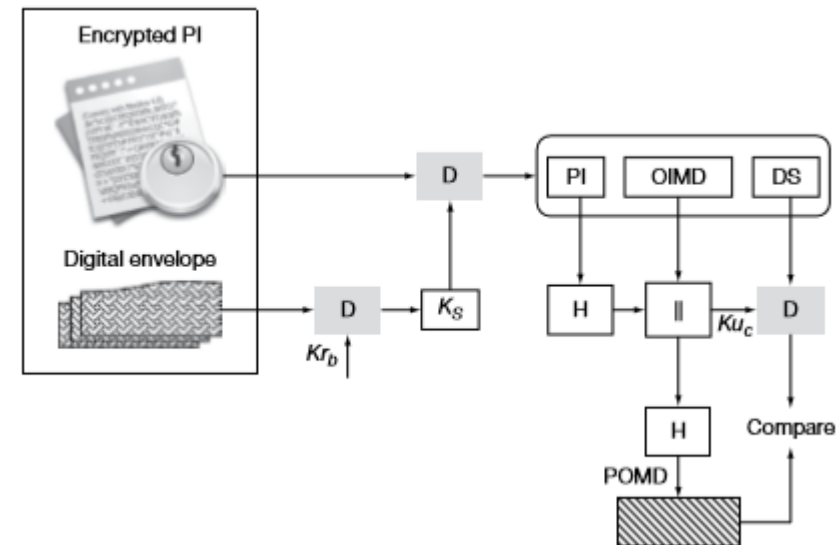
- After receiving the payment request from the customer, **the merchant uses the customer's public key, to verify the cardholder's DS.**
- In order to do that, the merchant decrypts the DS using the **public key of the customer.**
- The public key of the customer can be obtained from ***the certificate of the customer.***
- After decrypting, the merchant obtains POMD. This POMD is **compared with the hash value of concatenated PIMD and OIMD.**



- If both are equal, then the **merchant accepts the received DS as a valid one.**
- Once the DS is verified, the **merchant forwards the encrypted PI and digital envelope to the bank (issuer) through the payment gateway** and waits for payment authorization from the bank side.

4. Verification of payment information

- The acquirer in turn **forwards that information to the bank to check whether the debit/credit card used for transaction contains sufficient amount for completing the transaction.**
- In this case, the order details are removed by the merchant so that bank cannot find the order-related information.
- After receiving the **encrypted PI and digital envelope**, the bank decrypts the digital envelope to find the session key using the **private key of the bank**. After finding the session key, the bank decrypts the encrypted PI to get PI, OIMD and DS. Using the PI and OIMD, the bank computes the POMD.



- After that, the bank decrypts the DS to get POMD.
- Finally, it compares both the POMD values. **If both are equal, then the bank gives reply to merchant through the acquirer.**
- After receiving the **payment authorization reply from the acquirer, the merchant delivers the goods or products to the cardholder.**
- After some time, the merchant can claim the amount from the acquirer for all the transactions for which the acquirer has given authorization reply.
- The strength of encryption used in SET is measured by how hard to break it, which depends on factors such as the length of the key, configuration of computer, the algorithms used for encryption, etc.